

ABC Solutions Pvt. Ltd. – Information Security Risk Register

Risk ID	Asset	Threat	Vulnerability	Risk Description	Existing Controls	Likelihood	Impact	Inherent Risk Score	Inherent Risk Level	Risk Treatment	Treatment Action	Risk Owner	Target Date	Residual Likelihood	Residual Impact	Residual Risk Score	Residual Risk Level	Status
RISK-001	Corporate Email Accounts	Phishing Attack	Limited phishing-awareness training	Due to limited phishing awareness, an employee may disclose credentials through a phishing email, resulting in unauthorized access to company systems and sensitive information.	Email filtering, antivirus, password policy	4	4	16	High	Mitigate	Enable MFA for corporate email accounts and conduct quarterly phishing-awareness training.	Information Security	30-09-2026	2	4	8	Medium	In Progress
RISK-002	Employee Laptops	Ransomware	Unpatched software and unsafe email attachments	Due to unpatched software or unsafe email attachments, ransomware may infect employee laptops, resulting in data encryption and operational disruption.	Antivirus, endpoint protection, regular backups	4	5	20	Critical	Mitigate	Strengthen patch management and restrict unsafe email attachments.	IT Manager	15-10-2026	2	5	10	High	In Progress
RISK-003	Employee Credentials	Credential Theft	Weak or reused passwords	Due to weak or reused passwords, attackers may steal employee credentials, resulting in unauthorized access to company accounts.	Password policy, account lockout controls	4	4	16	High	Mitigate	Enforce MFA and strengthen password requirements for employee accounts.	Information Security	30-09-2026	2	4	8	Medium	In Progress
RISK-004	Customer Database	Unauthorized Access	Inadequate access controls	Due to inadequate access controls, unauthorized users may access the customer database, resulting in exposure or misuse of customer information.	User authentication, role-based access controls, access reviews	3	5	15	High	Mitigate	Strengthen role-based access controls and conduct periodic access reviews.	IT Manager	31-10-2026	2	5	10	High	In Progress
RISK-005	Company Information Systems	Privilege Misuse	Excessive user privileges	Due to excessive user privileges, users may misuse elevated permissions, resulting in unauthorized changes or access to company systems.	Access approval process, role-based permissions, periodic access reviews	3	4	12	High	Mitigate	Remove unnecessary privileges and perform quarterly privilege reviews.	IT Manager	31-10-2026	2	4	8	Medium	Open
RISK-006	Servers and Workstations	Exploitation of Vulnerabilities	Delayed security patching	Due to delayed security patching, attackers may exploit known vulnerabilities in servers or workstations, resulting in system compromise.	Antivirus, firewall, patch-management process	4	4	16	High	Mitigate	Establish regular patching schedules and prioritize critical security updates.	IT Manager	30-09-2026	2	4	8	Medium	In Progress
RISK-007	Sensitive Company Data	Data Exposure	Sensitive data is insufficiently protected	Due to insufficient protection of sensitive data, company information may be exposed to unauthorized parties, resulting in confidentiality and regulatory risks.	Access controls, encryption, data classification	3	5	15	High	Mitigate	Strengthen encryption and restrict access to sensitive information.	Information Security	15-11-2026	2	5	10	High	Open
RISK-008	Employee Laptops	Theft or Loss	Lack of full-disk encryption	Due to lack of full-disk encryption, loss or theft of an employee laptop may result in unauthorized access to company information stored on the device.	Device passwords, screen lock, remote device management	3	4	12	High	Mitigate	Enable full-disk encryption and remote device-lock/wipe capabilities.	IT Manager	15-10-2026	1	4	4	Low	In Progress
RISK-009	Backup System	Backup Failure	Backups are not regularly tested	Due to untested backups, backup failures may prevent successful data recovery, resulting in prolonged operational disruption or data loss.	Scheduled backups, backup monitoring	3	5	15	High	Mitigate	Conduct regular backup restoration tests and monitor backup failures.	IT Manager	31-10-2026	2	5	10	High	In Progress
RISK-010	Sensitive Company Data	Malicious Insider	Inadequate monitoring of sensitive-data access	Due to inadequate monitoring of sensitive-data access, a malicious insider may misuse authorized access, resulting in theft, alteration, or disclosure of company information.	Access controls, activity logging, segregation of duties	2	5	10	High	Mitigate	Strengthen activity monitoring and periodically review access to sensitive data.	Information Security	15-11-2026	1	5	5	Medium	Open
RISK-011	Third-Party Services	Vendor Compromise	Inadequate third-party security assessment	Due to inadequate third-party security assessment, compromise of a vendor may affect company systems or information, resulting in data exposure or service disruption.	Vendor agreements, access restrictions, periodic vendor reviews	3	4	12	High	Transfer	Include appropriate security and liability requirements in vendor contracts and maintain suitable cyber insurance where applicable.	Vendor Risk Manager	30-11-2026	2	4	8	Medium	In Progress
RISK-012	Company Network	Network Outage	Lack of network redundancy	Due to lack of network redundancy, a network failure may interrupt connectivity, resulting in disruption to business operations.	Firewall, network monitoring, backup network equipment	3	4	12	High	Mitigate	Implement network redundancy and establish procedures for network failures.	IT Manager	31-10-2026	2	4	8	Medium	Open
RISK-013	Cloud Storage	Unauthorized Data Exposure	Misconfigured cloud access permissions	Due to misconfigured cloud access permissions, unauthorized users may access cloud-stored information, resulting in sensitive data exposure.	Cloud authentication, access controls, logging	3	5	15	High	Mitigate	Review cloud configurations regularly and restrict public access to sensitive data.	IT Manager	15-10-2026	1	5	5	Medium	In Progress
RISK-014	Company Files and Records	Accidental Data Deletion	Excessive file modification/deletion permissions	Due to excessive file modification or deletion permissions, an employee may accidentally delete important company files, resulting in data loss or operational disruption.	Access permissions, backups, file recovery mechanisms	3	4	12	High	Mitigate	Restrict deletion permissions and implement tested file-recovery procedures.	Operations Manager	31-10-2026	2	4	8	Medium	In Progress
RISK-015	Company Website	Service Outage	Lack of service redundancy	Due to lack of service redundancy, a website or hosting failure may make the company website unavailable, resulting in service disruption and reputational impact.	Website monitoring, regular backups, hosting-provider support	2	3	6	Medium	Accept	No additional treatment required at present; monitor and review the accepted risk periodically.	IT Manager	N/A	2	3	6	Medium	Accepted

5×5 Information Security Risk Matrix

Impact ↓ / Likelihood →	1	2	3	4	5
5	5	10	15	20	25
4	4	8	12	16	20
3	3	6	9	12	15
2	2	4	6	8	10
1	1	2	3	4	5

Risk Level Legend

Risk Score	Risk Level
1–4	Low
5–9	Medium
10–16	High
17–25	Critical

Risk Rating Criteria

Likelihood Rating Criteria

Score	Likelihood	Meaning
1	Rare	Very unlikely to occur
2	Unlikely	Could occur but is not expected
3	Possible	Could reasonably occur
4	Likely	Expected to occur
5	Almost Certain	Expected to occur frequently

Impact Rating Criteria

Score	Impact	Meaning
1	Insignificant	Very limited impact
2	Minor	Small operational/security impact
3	Moderate	Noticeable business impact
4	Major	Serious operational, financial, regulatory, or security impact
5	Severe	Critical impact on the organization

Risk Level Criteria

Risk Score	Risk Level
1–4	Low
5–9	Medium
10–16	High
17–25	Critical

Risk Treatment Options

Treatment	Meaning	Example
Mitigate	Implement or strengthen controls to reduce the risk	Enable MFA and provide phishing-awareness training
Avoid	Stop the activity that creates the risk	Discontinue an unnecessarily risky service
Transfer	Share or shift some consequences of the risk to another party	Use appropriate insurance or contractual arrangements
Accept	Management knowingly accepts the risk within defined criteria	Accept a low risk when additional treatment is not justified

Risk Review Frequency

The Information Security Risk Register should be reviewed quarterly and whenever significant changes occur to the organization's systems, business processes, threat environment, or security requirements.